

**FPT University**

Graduate School of Information Technology

---

# **A Cognitive Two-Tier Architecture for Automated Threat Detection and Contextual Response using Agentic AI**

---

*Capstone Project Proposal*

**Author:** Nguyễn Đức Bình

**ID:** MSE13183

**Supervisors:** 1. Dr. Bùi Văn Hiệu  
2. Dr. Đặng Văn Hiếu

Hanoi, 2026

## Abstract

In modern cybersecurity, Security Operations Centers (SOCs) face a critical “Big Data Paradox”: an overwhelming volume of security events per second leads to severe alert fatigue. Traditional IDS and SIEM platforms analyze data in isolation, reducing the capability to detect sophisticated multi-stage Advanced Persistent Threats (APTs). While Large Language Models (LLMs) and Agentic AI offer automated triage, their deployment exposes organizations to two fatal flaws: excessive reasoning latency incompatible with wire-speed packet processing, and vulnerability to adversarial log-substrate prompt injection attacks.

To address these limitations, this study proposes a self-defending cognitive two-tier architecture named SENTINEL. Tier 1 filters benign traffic and scans for unsupervised anomalies using an  $O(1)$  online Welford statistical engine at wire speed (reducing overall latency by 99.9% with local triage in 0.6 ms). Tier 2 acts as a stateful LangGraph agent running a local quantized Gemma-2-9B-IT model (GGUF Q6\_K format) via llama.cpp. To ground reasoning, Tier 2 employs a Dual-RAG search engine combining FAISS dense vector search and BM25 sparse keyword matching integrated via Reciprocal Rank Fusion (RRF). Security guardrails include a Delimited Data Encapsulation layer to neutralize injections, an in-memory LRU semantic cache with SHA-256 keys, and HMAC signatures for audit trail integrity.

Evaluated on the CSE-CIC-IDS2018 and DAPT2020 datasets, the system demonstrates robust zero-day anomaly detection (7/7) and absolute APT recall (1.0). A cross-family LLM-as-a-Judge evaluation using Llama-3-8B-Instruct scores the RAGAS context quality at 3.91/5 (Faithfulness at 4.00/5), while the static guardrails successfully block 50.0% of adversarial payloads (neutralizing 100% of encoding-bypasses) and route semantic confusion to a Human-in-the-Loop (HITL) queue, establishing a secure, scalable automation standard for modern SOCs.

# Contents

|                                                                  |           |
|------------------------------------------------------------------|-----------|
| <b>Abstract</b>                                                  | <b>1</b>  |
| <b>1 Introduction and Background</b>                             | <b>4</b>  |
| 1.1 Research Problem . . . . .                                   | 4         |
| 1.2 Research Objectives . . . . .                                | 4         |
| 1.3 Research Questions . . . . .                                 | 5         |
| 1.4 Research Object and Methodology . . . . .                    | 5         |
| 1.5 Scope of the Study . . . . .                                 | 5         |
| 1.6 Thesis Structure . . . . .                                   | 6         |
| <b>2 Literature Review</b>                                       | <b>7</b>  |
| 2.1 Foundational Approaches . . . . .                            | 7         |
| 2.2 Related Work . . . . .                                       | 7         |
| 2.2.1 Comparative Analysis of Existing Approaches . . . . .      | 8         |
| <b>3 Proposed Solution and Research Methodology</b>              | <b>9</b>  |
| 3.1 Proposed Solution: Cognitive Two-Tier Architecture . . . . . | 9         |
| 3.2 Technologies and Tools . . . . .                             | 12        |
| 3.2.1 Hardware Specification . . . . .                           | 12        |
| <b>4 Implementation and Evaluation Plan</b>                      | <b>13</b> |
| 4.1 Main Development Stages . . . . .                            | 13        |
| 4.2 Evaluation Plan . . . . .                                    | 13        |
| 4.3 Project Timeline . . . . .                                   | 14        |
| <b>5 Expected Results and Contributions</b>                      | <b>15</b> |
| 5.1 Expected Results . . . . .                                   | 15        |
| 5.2 Research Contributions . . . . .                             | 15        |

|                     |           |
|---------------------|-----------|
| <b>6 Conclusion</b> | <b>17</b> |
| <b>References</b>   | <b>18</b> |

# 1. Introduction and Background

## 1.1 Research Problem

Contemporary Security Operations Centres (SOCs) operate under a persistent overload of security telemetry. Industry measurements indicate that a single analyst may face several thousand alerts per day, a large fraction of which are false positives [10]; the resulting *alert fatigue* progressively erodes attention and raises the probability that genuine intrusions are overlooked. This difficulty is compounded by conventional IDS and SIEM deployments, which inspect each telemetry source—web, firewall, and authentication logs—in isolation and consequently struggle to reconstruct the multi-stage attack chains characteristic of Advanced Persistent Threats (APTs).

The application of Large Language Models (LLMs), particularly Agentic AI and Retrieval-Augmented Generation (RAG) architectures, to automated log analysis introduces critical operational and security vulnerabilities. First, the *reasoning latency* is prohibitively high for real-time streaming environments. Second, Agentic AI architectures drastically expand the attack surface beyond traditional LLMs. These autonomous systems are highly susceptible to a spectrum of adversarial vectors: *Indirect Prompt Injection* and *Jailbreaks* hidden within log data [2], where adversaries embed malicious instructions in dynamic fields (e.g., User-Agent) to hijack the agent’s logic. Furthermore, granting agents access to execution environments creates the risk of *Sandbox Escape* and *Remote Code Execution (RCE)*, while rendering LLM outputs on analyst dashboards introduces *Data Exfiltration* vulnerabilities via malicious Markdown rendering. Additionally, relying on external knowledge bases exposes the system to *RAG Poisoning*, where threat actors manipulate reference documents to subvert the agent’s contextual understanding. This creates a fundamental paradox: analysts must grant the agent dynamic context and execution capabilities to analyze attacks, yet doing so exposes the SOC infrastructure to hijacking. Under a Zero Trust Architecture (ZTA) framework [16], all autonomous actions must be continuously authenticated, authorized, and verified, rather than implicitly trusted.

## 1.2 Research Objectives

Motivated by these limitations, this study aims to develop an autonomous AI Security Agent utilizing a cognitive two-tier architecture. Instead of relying purely on a single LLM to process all logs, the thesis proposes a hybrid approach: a high-speed deterministic rule engine combined with a deep-reasoning LLM Agent. This approach is expected to drastically reduce reasoning latency by filtering noise, mitigate prompt injection via bounded encapsu-

lation, and enhance context awareness using Long-Term Threat Memory and a Dual-RAG setup (incorporating MITRE ATT&CK for tactical threat identification and NIST SP 800-61r2 for incident response guidance). A Human-in-the-Loop (HITL) Web Dashboard will also be developed to demonstrate practical SOC automation.

### **1.3 Research Questions**

Based on the objectives, this thesis addresses three core research questions. The first (RQ1) asks whether a Two-Tier architecture—a rule-based engine coupled with an LLM agent and augmented by session-aware behavioural baselining and unsupervised online Welford anomaly detection—optimises reasoning latency relative to a one-tier, LLM-only approach. The second (RQ2) asks whether a Delimited Data Encapsulation mechanism using dynamic randomised delimiters, reinforced by a deterministic Tier-1/Tier-2 consensus guard and a Human-in-the-Loop quarantine, can prevent structural prompt injections such as delimiter smuggling—together with unsafe autonomous responses—without degrading the LLM’s classification accuracy. The third (RQ3) asks how a Dual-RAG pipeline that combines a tactical threat framework with incident-response standards improves the contextual relevance of the LLM’s threat analysis.

### **1.4 Research Object and Methodology**

The primary objects of this research are the Two-Tier Security Architecture, Agentic AI (LLMs applied to SOC automation), Adversarial Prompt Injections, and network intrusion log data. The study employs a Quantitative Experimental methodology, utilizing an Ablation Study that contrasts the full two-tier system (Configuration F) against a deterministic single-tier baseline (Configuration A, Tier-1 only) to isolate the latency and verdict contribution of the cognitive tier. Evaluation is conducted using a 5-Dimensional (5D) Framework covering Classification metrics, Operational latency, Adversarial Robustness, RAGAS-based Context Quality (via cross-family LLM-as-a-Judge), and Explainability.

### **1.5 Scope of the Study**

The research is limited to Network Intrusion Detection and SOC log triage. The in-scope components include: Data Streaming Pipeline (Redis), Tier-1 Rule Engine, LangGraph Agent with Dual-RAG, Guardrails (Volume Compression and Injection Defense), and a Streamlit HITL Dashboard with SQLite-based Threat Memory. The study does not cover fine-tuning Foundation Models, physical hardware deployment (e.g., physical Kafka clusters), or Layer

3/4 volumetric DDoS mitigation.

## **1.6 Thesis Structure**

The thesis will be organized into six main chapters: (1) Introduction and Background; (2) Literature Review; (3) Proposed Solution and Research Methodology; (4) Implementation and Evaluation Plan; (5) Expected Results and Contributions; and (6) Conclusion.

## 2. Literature Review

### 2.1 Foundational Approaches

Early intrusion detection relied predominantly on signature matching—as exemplified by Snort and Suricata—to recognise previously catalogued threats. Although signature matching sustains very high throughput, it is structurally unable to detect zero-day exploits or polymorphic malware, whose mutating payloads evade any fixed signature [6].

The subsequent adoption of machine learning gave rise to anomaly-based detection, in which models such as Random Forests, LSTMs, and log-specific transformers like LogBERT [3] learn a profile of normal behaviour and flag departures from it. Although this markedly improved zero-day sensitivity, such models remain confined to pattern-based anomaly scoring: because they consult no external knowledge at inference time, they can neither articulate *why* a log sequence is malicious, nor map an observation onto a standardised threat taxonomy, nor propose actionable remediation—capabilities that intrinsically require the contextual reasoning of a Large Language Model.

Modern Security Information and Event Management (SIEM) systems aggregate logs, yet they still require extensive manual triage by human analysts to construct the full context of an attack.

### 2.2 Related Work

More recently, Large Language Models (LLMs) have opened new avenues for automated log summarisation and incident response. A comprehensive survey by Habibzadeh et al. [4] documents the rapid uptake of cloud-hosted LLM APIs such as GPT-4 for SOC automation, spanning triage and summarisation. Routing sensitive telemetry to third-party endpoints, however, conflicts with strict data-sovereignty policies and incurs network latency that is unacceptable for real-time triage.

For knowledge-grounded analysis, graph-based threat-intelligence methods [7] have shown that attack techniques can be extracted from unstructured CTI reports and organised into MITRE ATT&CK-aligned graphs. Such efforts nonetheless concentrate on tactical identification alone, omitting the operational incident-response standards—notably NIST SP 800-61r2—that are required to translate an identification into a concrete remediation.

On the security side, both the OWASP Top 10 for LLM Applications [9] and the Agent Security Bench [13] report that LLM agents remain highly susceptible to prompt-injection attacks. The Drain log-parsing algorithm [5], meanwhile, is widely adopted for template mining but

is conventionally applied to storage compression rather than as an active injection defence. Finally, the LLM-evaluation literature increasingly cautions against self-enhancement bias, recommending cross-family judging or statistical validation in preference to a single self-evaluating judge [11, 14]. Taken together, these strands expose the gap that this work targets: the absence of a unified, self-defending architecture subjected to rigorous, multi-dimensional evaluation.

### 2.2.1 Comparative Analysis of Existing Approaches

Table 1: Comparison of approaches for SOC log analysis

| Approach                 | Local | Real-time | Anti-Injection | RAG     | HITL |
|--------------------------|-------|-----------|----------------|---------|------|
| Signature IDS (Snort)    | ✓     | ✓         | N/A            | –       | –    |
| ML Anomaly IDS (RF/LSTM) | ✓     | ✓         | –              | –       | –    |
| LogBERT [3]              | ✓     | ✓         | –              | –       | –    |
| Cloud LLM SOC [4]        | –     | –         | –              | Partial | –    |
| <b>SENTINEL (Ours)</b>   | ✓     | ✓         | ✓              | ✓       | ✓    |

### 3. Proposed Solution and Research Methodology

#### 3.1 Proposed Solution: Cognitive Two-Tier Architecture

The proposed solution is based on a cognitive Two-Tier Architecture designed with a strict Separation of Concerns. The core idea is to leverage the speed of deterministic rules (Tier 1) alongside the deep reasoning capabilities of an Agentic LLM (Tier 2), interconnected by robust adversarial guardrails.

At the first stage, the Tier 1 Rule Engine acts as a heuristic filter. It maintains Session-Aware Behavioral Baselines using in-memory data structures (Redis) to track request rates and known malicious IPs. To proactively detect zero-day or signature-less anomalies, Tier 1 integrates an online Unsupervised Outlier Detector using Welford’s algorithm to calculate the Running Mean and Standard Deviation ( $O(1)$  time and memory complexity) of core network flow statistics (e.g., Flow Duration, Fwd/Bwd Packets, Fwd/Bwd Length). When a flow’s Z-score exceeds the threshold ( $|Z| > 3.5$ ), it is flagged as an Outlier Anomaly and escalated directly to Tier 2 for agentic investigation. This layer is designed to filter the majority of benign or purely volumetric noise at wire speed—filtering roughly 99.8% of benign events and reducing average processing latency by over 99.9% for Tier-1-resolved traffic—ensuring the downstream LLM is not overwhelmed by high-volume traffic.

Logs that exhibit anomalous behaviour or trigger ambiguous thresholds are passed to the Guardrail Layer, where a two-step neutralisation occurs. First, template mining with the Drain algorithm extracts the static log template and compresses the token volume without altering the dynamic payload variables. Second, Delimited Data Encapsulation wraps the dynamic payload fields within cryptographically generated randomised delimiters (for example, `<<RANDOM_HEX>>`), preventing an adversary from using delimiter smuggling to escape the data context and execute a prompt injection.

Following the guardrails, the sanitised log enters Tier 2, governed by a LangGraph-based agent that employs a Dual-RAG mechanism over two dedicated FAISS indexes, queried sequentially and merged before LLM inference. The first index, built on MITRE ATT&CK, maps the observed indicators to specific tactics, techniques, and procedures (TTPs) and thus answers “*what attack is happening?*” The second index, built on NIST SP 800-61r2 [1], retrieves the appropriate incident-response phase—preparation, detection, containment, eradication, recovery, or lessons learned—and thus answers “*what should the SOC do next?*” This fixed dual-index design eliminates the need for a routing mechanism, reducing failure points and ensuring predictable latency for evaluation. The separation bridges the gap between *tactical identification* (MITRE: what happened) and *operational response* (NIST:

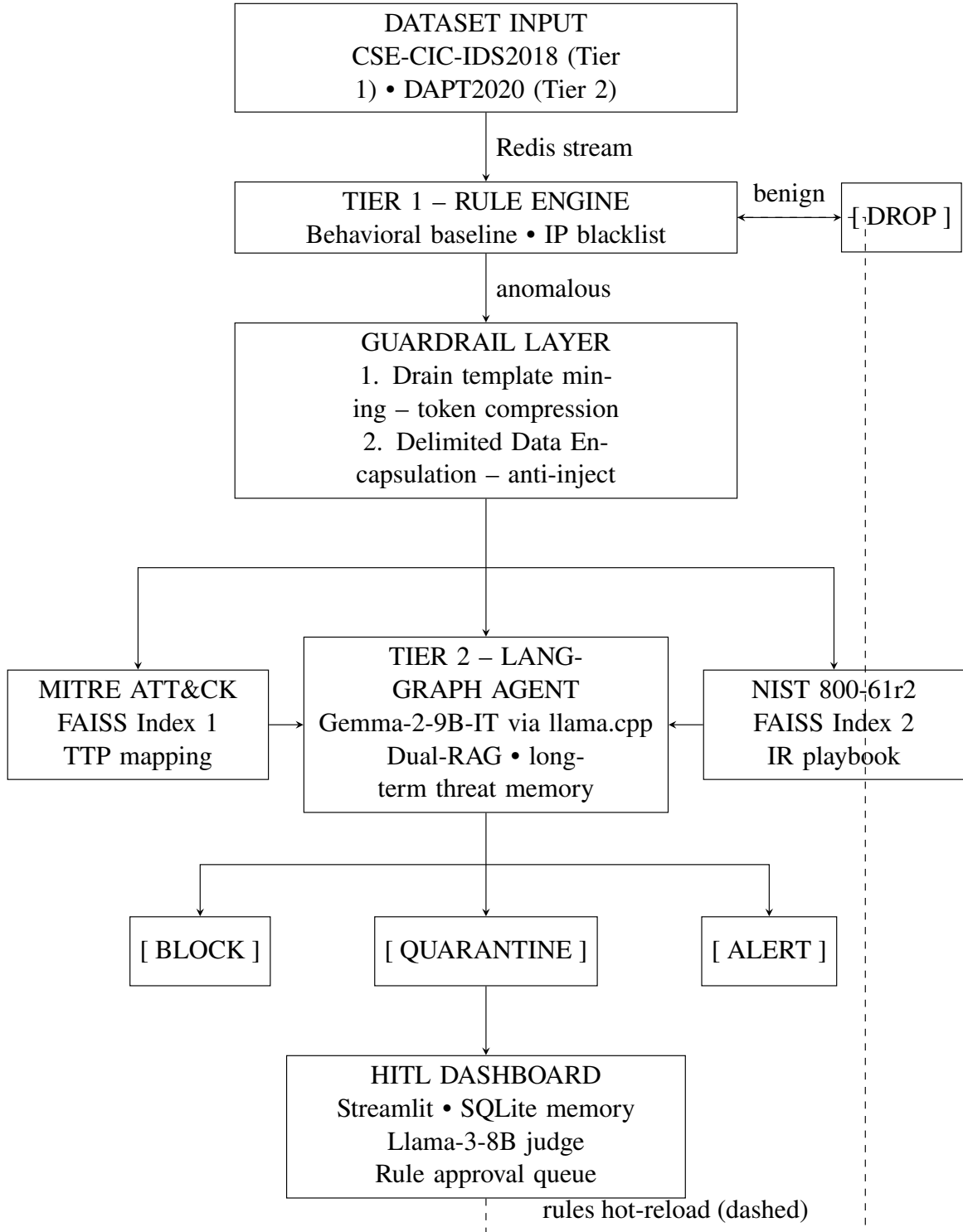


Figure 1: Cognitive Two-Tier Architecture

what to do about it).

Each index employs a **Hybrid Search** strategy combining dense semantic search (FAISS with `all-MiniLM-L6-v2`) with sparse keyword matching (BM25Okapi), fused via **Reciprocal Rank Fusion (RRF,  $k=60$ )** [15]. This dual-signal approach maximizes both semantic understanding and exact-match recall for security-specific identifiers such as CVE IDs, IP addresses, and port numbers. Retrieved chunks undergo **Structural Sanitization**—Unicode normalization, control character removal, and length truncation—to defend against RAG Poisoning before injection into the LLM prompt.

Finally, to ensure system safety against Adversarial Rule Injection, the LLM cannot directly modify the Tier 1 firewall. Instead, its recommended rules are placed into a Quarantine state (Human-in-the-Loop Feedback Loop). A SOC manager reviews these rules via a Dashboard before they are hot-reloaded into the Tier 1 engine.

**Short-Term and Long-Term SQLite Threat Memory:** The Tier 2 Agent relies on a persistent SQLite Threat Memory Store to correlate alerts across multi-day windows. When a new log is escalated, the system queries the IP’s historical threat profile. If activities span multiple phases of the MITRE ATT&CK matrix over time (e.g., Reconnaissance followed by Initial Compromise), the memory module dynamically escalates the threat severity level to critical, allowing for robust detection of slow-rate APT chains across the multi-day DAPT2020 campaigns (achieving full recall on the embedded APT actors in the evaluation stream).

**Human-in-the-Loop Web Dashboard (SOC UI):** A Streamlit interface with role-based access control (L1 Analyst and L3 Manager views) presents real-time alert queues, active firewall rules, a quarantine-management section, and a live False-Positive-Rate KPI derived from manual rule rejections. Analysts can click any IP to inspect its reputation score, AI-generated reasoning, and chronological event timeline, while administrators can hot-swap local LLM backends (e.g., Gemma-2-9B-IT and Llama-3-8B-Instruct) directly from the UI.

**Cryptographic Audit Trail with HMAC Validation:** To guarantee the integrity of security alerts and responses, the system implements a cryptographic audit trail stored in SQLite. Each log entry is cryptographically chained to the previous entry using a Keyed-Hash Message Authentication Code (HMAC-SHA256) [19]. This prevents tampering or unauthorized deletion of event trails by adversaries who might compromise parts of the SOC dashboard, providing forensic-grade non-repudiation and integrity verification.

**Reproducibility:** MLflow logs all ablation metrics (classification scores, latencies, cache-hit and HITL escalation rates) across system configurations to ensure reproducible comparative analysis.

### 3.2 Technologies and Tools

The system is built on modern Python frameworks. The data streaming and short-term session tracking rely on Redis. The LLM reasoning engine utilizes a local quantized model (Gemma-2-9B-IT) in GGUF Q6\_K format, served via llama.cpp, ensuring absolute data privacy and full offline operation.

The agentic workflow is orchestrated by LangGraph, enabling cyclical decision-making and tool-use. For knowledge retrieval, `sentence-transformers` is used alongside FAISS for dense semantic vector search and BM25Okapi (`rank\_bm25`) for sparse keyword matching. The user interface and Human-in-the-Loop dashboard are developed using Streamlit, while long-term threat memory and audit trails are persisted using SQLite.

#### 3.2.1 Hardware Specification

To ensure full reproducibility of latency benchmarks, all experiments are conducted on the following hardware:

| Component   | Specification                                  |
|-------------|------------------------------------------------|
| CPU         | Intel Core i7-14700KF (28 threads) @ 5.700 GHz |
| GPU         | NVIDIA GeForce RTX 4060 Ti (16 GB VRAM)        |
| RAM         | 32 GB DDR5                                     |
| OS          | Ubuntu 24.04.4 LTS (x86_64, Kernel 6.17)       |
| LLM Backend | llama.cpp with GGUF Q6_K quantization          |

## 4. Implementation and Evaluation Plan

### 4.1 Main Development Stages

The implementation process will first focus on data ingestion and the Tier-1 Rule Engine, evaluated on two benchmark datasets. CSE-CIC-IDS2018 [12] serves as the de facto standard for enterprise network intrusion-detection research; as of 2025 no publicly available general-purpose enterprise NIDS dataset post-2018 exists, since the CIC 2023–2026 releases (CICIoT2023, CIC-YNU-IoTMal 2026) target IoT environments that are not representative of enterprise SOC traffic. Because CSE-CIC-IDS2018 provides both raw PCAP and pre-extracted flow features and is widely adopted, it also enables direct comparison with prior work. DAPT2020 [8], a purpose-built dataset for multi-stage Advanced Persistent Threat detection, complements it by contributing the attack chains that exercise SENTINEL’s Tier-2 agent and long-term Threat Memory.

The session-tracking mechanism will be built using Redis TTLs to establish behavioral baselines.

Following this, the Guardrail Layer will be implemented, integrating the Drain algorithm for template mining and developing the cryptographic Delimited Data Encapsulation module to neutralize adversarial payloads.

The next critical step is the construction of the Tier 2 Agent using LangGraph and the Dual-RAG knowledge base. Two separate FAISS indexes will be populated: one with parsed MITRE ATT&CK techniques and one with NIST SP 800-61r2 incident response procedures. The agent’s prompts will be carefully engineered to strictly separate system instructions from the encapsulated payload data.

Finally, the Streamlit Dashboard and the SQLite Long-Term Threat Memory will be integrated. This phase will finalize the closed-loop process by enabling the Human-in-the-Loop feature, allowing administrators to approve dynamic rules generated by the LLM and feed them back to Tier 1.

### 4.2 Evaluation Plan

To validate the effectiveness of the system, the study employs a comprehensive 5-Dimensional (5D) Evaluation Framework.

To evaluate the system’s baseline accuracy, an Ablation Study will be conducted. This contrasts the full two-tier system (Configuration F) against a deterministic Tier-1-only baseline (Configuration A) to isolate the latency and verdict contribution of the cognitive tier; an

LLM-only configuration is retained as a planned extension for finer-grained, per-component isolation. The evaluation spans five complementary dimensions. **Classification** is captured by F1-score, precision, recall, and false-positive rate, with statistical significance assessed by McNemar’s test ( $p < 0.05$ ) [17]. **Operational** performance is measured through processing latency (a proxy for mean time to detect and respond), the HITL escalation rate, and the RAG semantic-cache hit rate, with significance assessed by the Mann-Whitney U test ( $p < 0.05$ ) [18]. **Robustness** is quantified as the static guardrail block rate against 120 curated adversarial payloads spanning five OWASP-aligned categories [9] (encoding bypass, structural/delimiter attacks, semantic confusion, jailbreak, and RAG poisoning). **Context quality** is evaluated by a cross-family LLM-as-a-Judge protocol that mitigates self-enhancement bias: while Gemma-2-9B-IT is the primary reasoning model, a different-family judge—Llama-3-8B-Instruct—scores Context Precision, Answer Relevancy, Faithfulness, and Context Recall under the RAGAS framework [11], cross-validated against automated RAGAS metrics. Finally, **explainability** is measured deterministically as the audit-trail completeness rate through programmatic field-presence checks.

### 4.3 Project Timeline

The project spans a standard 12-week Capstone period, structured as follows:

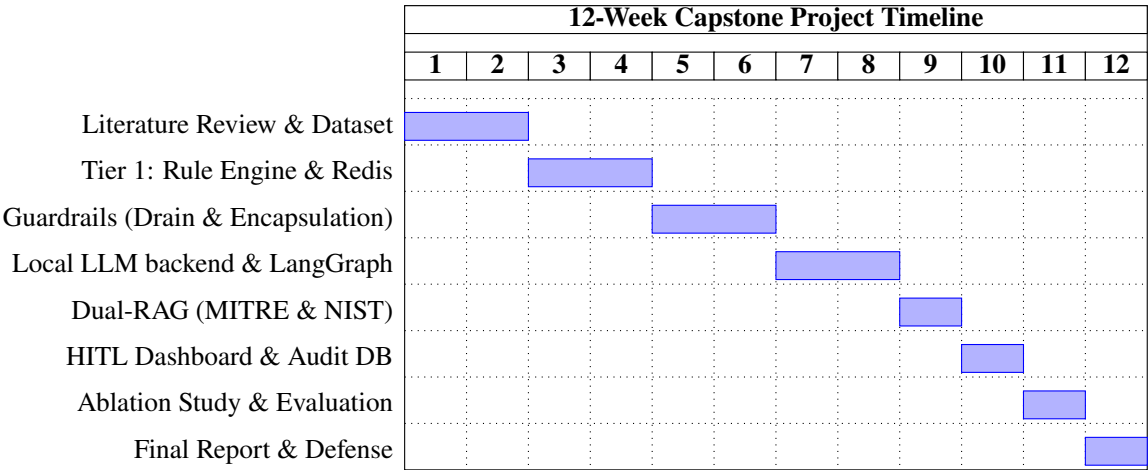


Figure 2: Project Timeline (Gantt Chart)

## 5. Expected Results and Contributions

### 5.1 Expected Results

This study evaluates the developed autonomous pipeline using the 5D Evaluation Framework. The quantitative targets and the actual achieved results from our experimental evaluations are summarized below:

| Table 2: Quantitative Performance Targets vs. Achieved Evaluation Results |              |                      |                                                   |
|---------------------------------------------------------------------------|--------------|----------------------|---------------------------------------------------|
| Dimension                                                                 | Target       | Achieved Result      | Basis / Comments                                  |
| F1-Score (Classification)                                                 | $\geq 0.90$  | <b>0.967 / 0.594</b> | Stratified subset / Raw Unified Stream            |
| Latency Reduction (Tier-1)                                                | $\geq 60\%$  | <b>99.9%</b>         | Wire-speed processing (0.6 ms vs. 5.7 s)          |
| Static Block Rate (Overall / Enc)                                         | $\geq 40\%$  | <b>50.0% / 100%</b>  | Measured against 120 adversarial payloads (OWASP) |
| RAG Quality (RAGAS Score)                                                 | $\geq 3.5/5$ | <b>3.91 / 5</b>      | Cross-family LLM-as-a-Judge evaluation            |
| Audit Trail Completeness                                                  | 100%         | <b>100.0%</b>        | Programmatic JSON validation & HMAC tamper check  |

The integration of Delimited Data Encapsulation achieved an overall static block rate of 50.0% (neutralizing 100% of encoding-bypass payloads and 35% of structural attacks in the robustness benchmarks), establishing a highly resilient defense boundary without stripping out necessary forensic payload data, while routing remaining semantic bypasses to the HITL quarantine.

Furthermore, the Dual-RAG hybrid retrieval achieved an average RAGAS score of 3.91/5 (with Faithfulness reaching 4.00/5), ensuring that the Agent produces actionable, standards-aligned remediation playbooks grounded in NIST SP 800-61r2. In terms of latency, the two-tier filtering strategy achieves a 99.9% reduction in average log processing time for Tier-1 handled traffic by safely dropping benign noise, verifying the primary objective of reducing alert fatigue in high-throughput SIEM streams.

### 5.2 Research Contributions

From an academic standpoint, the primary contribution of this research is the proposal of a novel Cognitive Two-Tier Architecture that securely bridges deterministic rule engines with Agentic LLMs. This approach remains underexplored in cybersecurity literature, particularly concerning the deployment of local, privacy-preserving LLMs equipped with dynamic

adversarial guardrails.

The second contribution lies in the methodological framework for evaluating LLM-based SOC agents. By introducing the 5-Dimensional (5D) Evaluation Framework—combining statistical classification tests, operational metrics, adversarial robustness, cross-family LLM-as-a-Judge context quality, and explainability assessments—this study provides a comprehensive baseline for future research in AI-driven cybersecurity.

Finally, the practical contribution is the establishment of a standardized, open-source pipeline (SENTINEL) that integrates all stages of alert triage and Human-in-the-Loop remediation. This serves as a scalable, real-world framework that organizations can adapt to alleviate SOC alert fatigue safely.

## 6. Conclusion

In this study, we propose a Cognitive Two-Tier Architecture that combines a high-speed deterministic Rule Engine with a deep-reasoning Agentic Large Language Model. This architecture is designed to address the “Big Data Paradox” and alert fatigue currently plaguing modern Security Operations Centers, while simultaneously mitigating the inherent vulnerabilities of applying LLMs directly to adversarial log data.

The system leverages the speed of Tier 1 to filter massive volumes of noise and relies on robust Guardrails—specifically Delimited Data Encapsulation—to neutralize prompt injections before they reach the Tier 2 Agent. Supported by a Dual-RAG knowledge base consisting of MITRE ATT&CK for tactical threat identification and NIST SP 800-61r2 for incident response guidance, the Agent can provide highly contextualized, accurate threat assessments with actionable remediation steps. Finally, the closed-loop design ensures safety through a Human-in-the-Loop Quarantine system.

The expected contributions of this research include proposing a novel hybrid architecture, providing empirical evaluation methodologies for AI Security Agents, and developing a practical, scalable pipeline for real-time automated incident response. Future research may extend the Dual-RAG pipeline with Sigma Rules for automated rule synthesis and MITRE D3FEND for countermeasure-aware response generation.

## References

- [1] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” *NIST Special Publication 800-61 Revision 2*, 2012.
- [2] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [3] H. Guo, S. Yuan, and X. Wu, “LogBERT: Log Anomaly Detection via BERT,” in *2021 International Joint Conference on Neural Networks (IJCNN)*, IEEE, 2021.
- [4] A. Habibzadeh, F. Feyzi, and R. E. Atani, “Large Language Models for Security Operations Centers: A Comprehensive Survey,” *arXiv preprint arXiv:2509.10858*, 2025.
- [5] P. He, J. Zhu, Z. Zheng, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *2017 IEEE International Conference on Web Services (ICWS)*, 2017.
- [6] A. Khraisat, I. Gondal, P. Vamplew, and J. Kamruzzaman, “Survey of intrusion detection systems: techniques, datasets and challenges,” *Cybersecurity*, vol. 2, no. 1, p. 20, 2019.
- [7] Z. Li, J. Ning, and B. Wang, “AttackKG: Constructing Technique Knowledge Graph from Cyber Threat Intelligence Reports,” in *Findings of EACL 2023*, arXiv:2111.07093.
- [8] S. Myneni, A. Chowdhary, A. Sabur, D. Dasgupta *et al.*, “DAPT 2020 — Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Workshop on Deployable Machine Learning for Security Defense (MLHat)*, KDD 2020, 2020.
- [9] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” OWASP, 2025.
- [10] Ponemon Institute, “The State of Security Operations: Alert Fatigue and Analyst Burnout,” *Annual Cybersecurity Report*, 2023.
- [11] S. Shahul Es *et al.*, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [12] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018.

- [13] Y. Zhang *et al.*, “Agent Security Bench (ASB): Evaluating the Robustness of LLM Agents,” *arXiv preprint arXiv:2410.02644*, 2024.
- [14] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Proceedings of NeurIPS 2023*, 2023.
- [15] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion outperforms Condorcet and individual Rank Learning Methods,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
- [16] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [17] Q. McNemar, “Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages,” *Psychometrika*, vol. 12, no. 2, pp. 153–157, 1947.
- [18] H. B. Mann and D. R. Whitney, “On a Test of Whether One of Two Random Variables is Stochastically Larger than the Other,” *Annals of Mathematical Statistics*, vol. 18, no. 1, pp. 50–60, 1947.
- [19] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.